

Remediation Guide

CloudExify Cybersecurity Internship — Project 3: Web Application Penetration Testing

This guide summarizes each confirmed vulnerability from the DVWA web application penetration test and provides concrete, prioritized remediation steps for developers and system administrators. Findings are ordered by severity.

1. SQL Injection

Severity	Critical
Fix Timeline	Immediate (0–24 hours)

- Use parameterized queries / prepared statements for every database call — never concatenate user input into SQL strings.
- Apply strict server-side input validation (e.g., enforce numeric-only for ID fields).
- Run the application's database account with least-privilege access (no unnecessary SELECT/DROP/UNION rights).
- Deploy a Web Application Firewall (WAF) as an additional layer of defense.

2. Unrestricted File Upload (Remote Code Execution)

Severity	Critical
Fix Timeline	Immediate (0–24 hours)

- Validate uploaded file type via server-side content/MIME inspection — never trust the file extension alone.
- Store uploaded files outside the web root, or in a directory where script execution is disabled.
- Rename uploaded files to random, non-executable names on save.
- Enforce an allow-list of accepted file types (e.g., .jpg, .png) and a maximum file size.

3. Cross-Site Request Forgery (CSRF)

Severity	High
Fix Timeline	1–7 days

- Implement unique, unpredictable anti-CSRF tokens on all state-changing requests, validated server-side.
- Require re-entry of the current password before allowing a password change.
- Set cookies with SameSite=Strict or SameSite=Lax.
- Avoid performing state-changing actions via GET requests; use POST with proper validation.

4. Stored Cross-Site Scripting (XSS)

Severity	High
Fix Timeline	1–7 days

- HTML-encode all user-supplied output before rendering (e.g., htmlspecialchars() in PHP).
- Apply a Content Security Policy (CSP) to restrict inline script execution.

- Sanitize input server-side using an allow-list approach for any permitted formatting.

5. Reflected Cross-Site Scripting (XSS)

Severity	Medium
Fix Timeline	1–30 days

- HTML-encode all reflected user input before rendering it in the response.
- Use templating engines that auto-escape output by default (e.g., Jinja2, Django templates).
- Apply a Content Security Policy (CSP) as an additional defense layer.

6. DOM-Based Cross-Site Scripting (XSS)

Severity	Medium
Fix Timeline	1–30 days

- Avoid inserting untrusted data into the DOM via unsafe sinks (innerHTML, document.write).
- Use safe DOM APIs such as textContent, or sanitize with a trusted library (e.g., DOMPurify).
- Apply a strict Content Security Policy to limit the impact of any successful injection.

7. Authentication Bypass — No Account Lockout

Severity	Medium
Fix Timeline	1–30 days

- Implement account lockout after a defined number of failed login attempts, with exponential backoff.
- Add a CAPTCHA or similar challenge after repeated failures.
- Enforce strong password policies to reduce the chance of weak/common passwords being valid.
- Implement multi-factor authentication (MFA), especially for administrative accounts.

Summary Priority Table

Vulnerability	Severity	Fix Timeline
SQL Injection	Critical	0–24 hours
Unrestricted File Upload	Critical	0–24 hours
CSRF	High	1–7 days
Stored XSS	High	1–7 days
Reflected XSS	Medium	1–30 days
DOM-Based XSS	Medium	1–30 days
Authentication Bypass	Medium	1–30 days